Cyber-Security und Barrierefreiheit software:112

Rechtslage, Bestandsaufnahme und Maßnahmenplan · IC&P Consultants e.U. · Stand 23. September 2026

Kein neues Gesetz verpflichtet software:112 direkt, aber zwei Dinge machen das Thema dringend: Ab 1. Oktober 2026 gilt das NISG 2026, und größere Weinbaubetriebe werden als „wichtige Einrichtung“ Nachweise von ihren IT-Lieferanten verlangen. Und unser eigener Vertrag V2 (Anlage 3, Abschnitt 9) sagt Sicherheitsupdates binnen 14 Tagen zu – eine offene Schwachstelle mit Stufe „hoch“ in nodemailer ist heute schon ein Verstoß dagegen. Die Bestandsaufnahme zeigt eine solide Basis bei Mandantentrennung und Datenbankrechten, sechs Lücken bei Anmeldung und Absicherung, die vor dem Start weiterer Betriebe geschlossen werden sollten, und deutlichen Nachholbedarf bei der Barrierefreiheit der Oberfläche.

Diese Einschätzung ist keine Rechtsberatung; die rechtliche Einordnung sollte mit Rechtsanwältin Sabine Barbach abgestimmt werden.

Rechtslage in Österreich (Stand 23.9.2026)

Regelung	Gilt ab	Für software:112	Für die Weinbaubetriebe
NISG 2026 (Umsetzung NIS-2)	1.10.2026; Registrierung bis 31.12.2026	Nicht direkt erfasst: Cloud- und IT-Dienstleister fallen erst ab mittlerer Größe darunter (ab 50 Beschäftigte oder über 10 Mio. € Umsatz und Bilanzsumme).	Lebensmittel (Produktion, Verarbeitung, Vertrieb) ist erfasst, ebenfalls ab mittlerer Größe. Ein solcher Betrieb muss die Sicherheit seiner Lieferkette nachweisen – und fragt dann bei uns nach.
Cyber Resilience Act (EU)	Meldepflichten ab 11.9.2026, vollständig ab 11.12.2027	Reine SaaS-Software ist laut Leitlinien der EU-Kommission (März 2026) nicht erfasst.	nicht betroffen
DSGVO Art. 32 und 33	gilt bereits	Pflicht zu angemessenen technischen und organisatorischen Maßnahmen; Datenpanne binnen 72 h an die Datenschutzbehörde. Das ist die eigentliche Rechtsgrundlage für alle Sicherheitsmaßnahmen hier.	Als Verantwortliche auf unsere Auftragsverarbeitung (AVV) angewiesen
Barrierefreiheitsgesetz (BaFG)	28.6.2025	Gilt für Dienstleistungen im elektronischen Geschäftsverkehr mit Verbrauchern (B2C). software:112 ist eine B2B-Software und daher nicht unmittelbar erfasst; Kleinstunternehmen (unter 10 Beschäftigte und höchstens 2 Mio. € Umsatz oder Bilanz) sind bei Dienstleistungen ohnehin ausgenommen. Strafen bis 80.000 €.	Betrifft ihre eigenen Verbraucher-Angebote (Webshop, Buchung), wenn sie keine Kleinstunternehmen sind. Aus software:112 gehen Newsletter an Verbraucher.
Barrierefreiheit bei öffentlichen Auftraggebern	gilt bereits	Weinbauschulen, Kammern oder Landesstellen fordern bei Vergaben üblicherweise die Norm EN 301 549 bzw. WCAG 2.1 Stufe AA.	–

Folgerung: Sicherheit ist über DSGVO und Vertrag schon heute geschuldet, NIS-2 kommt über die Kunden. Bei der Barrierefreiheit gibt es keine Pflicht, aber WCAG 2.1 AA ist der Maßstab, an dem öffentliche und größere Kunden uns messen werden, und Barrierefreiheit hilft auch älteren Winzerinnen und Winzern sowie der Bedienung am Handy im Keller.

Ist-Stand Cyber-Security

Was bereits gut abgesichert ist

- Mandantentrennung doppelt: Zeilenrechte (RLS) auf allen Tabellen, dazu prüft ein Skript bei jedem Build, dass jede Abfrage auf den aktiven Betrieb gefiltert ist; der Build bricht sonst ab.
- Deaktivierte Mitgliedschaften sperren sofort den Zugriff auf alle Daten des Betriebs (restriktive Richtlinie, Migration 221).
- Rollen und Schreibrechte je Modul; Leser können nichts ändern.
- Automatische Abmeldung nach Inaktivität, je Betrieb einstellbar.
- Zugangsdaten für Postfächer werden verschlüsselt gespeichert; Microsoft 365 nur mit delegierten Rechten des jeweiligen Benutzers.
- „Frag dein Weingut“ führt nur lesende Abfragen aus, eingeschränkt auf den aktiven Betrieb und eine Liste erlaubter Tabellen.
- Zeitgesteuerte Aufgaben nur mit geheimem Schlüssel; Fehlerprotokoll (Systembericht) und Rechte-Test (Smoke-Test) für alle Rollen.
- Tägliche Datensicherung mit 7 Tagen Aufbewahrung.

Befunde

Nr.	Befund	Risiko	Maßnahme	Aufwand
S1	Microsoft-365-Verbindung: der Rückkanal nach der Anmeldung übernimmt Betrieb und Benutzer aus einem ungeschützten Parameter und prüft nicht, wer angemeldet ist. Ein Angreifer könnte sein eigenes Postfach einem fremden software:112-Konto unterschieben und so dessen gesendete E-Mails mitlesen.	hoch	Parameter signieren (mit Einmal-Wert und Ablauf) und mit der angemeldeten Sitzung abgleichen	1–2 h
S2	Der Schlüssel für die Postfach-Verschlüsselung fällt auf einen im Quellcode stehenden Ersatzwert zurück, wenn die Umgebungsvariable fehlt; in der lokalen Konfiguration fehlt sie. Außerdem wird ohne Integritätsschutz verschlüsselt (AES-CBC).	hoch, zu prüfen	In Vercel prüfen, dass EMAIL_CRYPT_SECRET gesetzt ist; Ersatzwert entfernen (Start ohne Schlüssel verweigern); auf AES-GCM umstellen und Bestand umschlüsseln	0,5 h + 2–3 h
S3	Keine Zwei-Faktor-Anmeldung. Ein erratenes oder abgefischtes Passwort eines Betriebs-Managers öffnet den ganzen Betrieb.	hoch	Zwei-Faktor mit Authenticator-App (von Supabase unterstützt): Pflicht für Super-Admin und Betriebs-Manager, freiwillig für alle anderen	6–10 h
S4	Abhängigkeiten: npm audit meldet 1 hohe Schwachstelle (nodemailer, 4 Hinweise, u. a. Zustellung an fremde Domains) und 2 mittlere (qs, baseline-browser-mapping).	hoch (Vertrag: 14 Tage)	npm audit fix, Test des E-Mail-Versands; danach wöchentliche automatische Prüfung (Dependabot)	1 h + 1 h
S5	16 Datenbankfunktionen mit erhöhten Rechten sind ohne Anmeldung aufrufbar. Zwei davon prüfen den Zugriff nicht: über kundennummer_vergeben lässt sich die Kundennummer eines Betriebs abfragen oder vergeben, wenn man dessen interne Kennung kennt. Dazu 8 Funktionen ohne festen Suchpfad.	mittel	Ausführungsrecht für „anon“ entziehen, Suchpfad festlegen (eine Migration)	1–2 h

Nr.	Befund	Risiko	Maßnahme	Aufwand
S6	Keine Sicherheits-Header: die App kann in fremde Seiten eingebettet werden (Clickjacking), kein erzwungenes HTTPS über HSTS, keine Content-Security-Policy.	mittel	HSTS, frame-ancestors/X-Frame-Options, Referrer-Policy, Permissions-Policy, X-Content-Type-Options; Content-Security-Policy zuerst im Beobachtungsmodus	2–4 h
S7	Die Bildoptimierung lädt Bilder von beliebigen Adressen nach (für Betriebslogos gedacht) und kann als offener Proxy missbraucht werden.	niedrig	Auf Supabase-Speicher und bekannte Logo-Hosts beschränken, Logos künftig hochladen statt verlinken	0,5–1 h
S8	Microsoft-Webhook verwendet die Kennung des Betriebs als Prüfwert; Kennungen sind kein Geheimnis.	niedrig	Zufälligen Prüfwert je Abonnement speichern und vergleichen	1 h
S9	Altlasten: leere Debug-Route, CORS „*“ auf der Postfach-Abfrage.	niedrig	Entfernen	0,5 h
S10	Nachtrag 23.9.: Die Serverfunktionen laufen in Washington (Vercel-Standardregion iad1), der AVV (Anhang B) sagt Frankfurt zu. Zusätzlich geht jede Datenbankabfrage über den Atlantik nach Irland.	hoch (Vertrag)	Region fest auf Frankfurt (fra1) stellen	0,25 h

Organisatorisch (nicht im Code)

Nr.	Maßnahme	Warum	Aufwand
O1	Notfallplan für Sicherheitsvorfälle: wer entscheidet, wer informiert Betriebe und Datenschutzbehörde (72 h), Vorlage für die Meldung, Kontaktkette IC&P/Hohenstein	DSGVO Art. 33; NIS-2-Kunden verlangen Meldung binnen 24 h	2–4 h
O2	Sicherheitsblatt für Kunden: technische und organisatorische Maßnahmen, Unterauftragnehmer (Supabase, Vercel, Brevo, Anthropic, Stripe), Meldeweg – als Anhang zur AVV und Antwort auf Lieferanten-Fragebögen	Nachweis für NIS-2-Kunden	3–4 h
O3	security.txt und Sicherheits-Kontaktadresse auf der Website	Meldeweg für Schwachstellen	0,5 h
O4	Einstellungen prüfen: Supabase-Passwortrichtlinie (mind. 12 Zeichen, Schutz vor bekannten geleakten Passwörtern), Vercel Pro (Deployment-Schutz, längere Log-Aufbewahrung), Zugänge zu Supabase/Vercel/GitHub nur mit Zwei-Faktor	Angriffsfläche der Betreiberkonten	1–2 h
O5	Jährlicher Wiederherstellungstest der Datensicherung (im Vertrag zugesagt)	Vertrag Anlage 3, Abschnitt 6	2 h
O6	Externer Penetrationstest, bevor mehr als 10 Betriebe live sind	Unabhängiger Nachweis für größere Kunden	extern, Angebot einholen

Ist-Stand Barrierefreiheit

Maßstab ist WCAG 2.1 Stufe AA (Grundlage der EN 301 549). Geprüft wurden Quellcode und Farbwerte; ein Test mit Bildschirmleser steht noch aus.

Was bereits passt

- Seitensprache ist Deutsch ausgezeichnet, sodass Vorleseprogramme richtig aussprechen.
- Fließtext (#22252B), sekundärer Text (#5A5D66, 6,6 : 1) und blaue Links (#2F63AC, 6,0 : 1) erfüllen den geforderten Kontrast von 4,5 : 1.
- 9 von 10 Bildern haben einen Alternativtext; 83 Bedienelemente sind bereits für Vorleseprogramme benannt.
- Termine im Kalender lassen sich außer per Ziehen auch über den Bearbeiten-Dialog verschieben.

Befunde

Nr.	Befund	WCAG	Maßnahme	Aufwand
B1	Formularfelder: von 801 Beschriftungen sind nur 22 technisch mit ihrem Eingabefeld verbunden. Ein Vorleseprogramm liest dann nur „Eingabefeld“ statt „Rechnungsnummer“.	1.3.1, 4.1.2	Gemeinsame Feld-Komponente mit automatischer Verknüpfung; schrittweise umstellen, zuerst Verkauf, Kellerbuch, Anmeldung	8–16 h
B2	Kontraste zu schwach: Meta-Text (#A0A3AB, 2,5 : 1, 285 Stellen), Warnfarbe als Text (#D9A441, 2,3 : 1), Aktionsfarbe mit weißer Schrift (#4F86D6, 3,6 : 1). Die Betriebsfarben aus dem Branding werden gar nicht geprüft.	1.4.3, 1.4.11	Farbwerte nachdunkeln (Meta-Text auf #6E717A wie der übrige gedämpfte Text, 4,9 : 1, Warn-Text auf #8A6415); Kontrastprüfung mit Warnung im Branding-Dialog	4–6 h
B3	Dialoge: von 15 Überlagerungen sind 4 als Dialog ausgezeichnet; Fokus bleibt nicht im Dialog, Escape schließt nicht überall.	2.1.2, 2.4.3, 4.1.2	Eine gemeinsame Dialog-Komponente mit Fokusfalle, Escape und Rückkehr des Fokus	6–10 h
B4	Tastaturbedienung: 12 klickbare Flächen sind keine Schaltflächen; einige Symbol-Schaltflächen (Schließen-X u. a.) haben keinen Namen.	2.1.1, 4.1.2	In Schaltflächen umwandeln, Namen ergänzen	3–5 h
B5	Fokus unsichtbar: an 62 Stellen wird der Fokusrahmen entfernt, ohne Ersatz. Wer mit Tastatur arbeitet, sieht nicht, wo er ist.	2.4.7	Einheitlicher Fokusrahmen global (focus-visible)	1–2 h
B6	Sehr kleine Schrift (9–10,5 px) an rund 125 Stellen; Vergrößerung auf 200 % ungeprüft.	1.4.4	Mindestens 11–12 px; Test bei 200 % Zoom	2–4 h
B7	Kein Sprunglink „Zum Inhalt“, keine Rücksicht auf reduzierte Bewegung.	2.4.1, 2.3.3	Sprunglink und Einstellung für reduzierte Animation	1 h
B8	Newsletter gehen an Verbraucher: Alternativtexte für Bilder und Kontrast in den Vorlagen sind nicht erzwungen.	1.1.1, 1.4.3	Pflichtfeld Alternativtext, Kontrastprüfung in der Vorlage	2 h
B9	Kein automatischer Test und keine Barrierefreiheitserklärung.	–	axe-Prüfung in den Build aufnehmen; kurze Barrierefreiheitsinformation auf der Website (Stand, bekannte Einschränkungen, Kontakt)	3–4 h

Rechnungen und andere erzeugte PDFs sind nicht barrierefrei getaggt; das ist mit der verwendeten PDF-Bibliothek derzeit kaum lösbar und bleibt als bekannte Einschränkung in der Erklärung stehen.

Maßnahmenplan und Aufwand

Zusammen rund 55–90 Stunden, davon 6–9 Stunden für das, was vor dem 1. Oktober erledigt sein sollte. Die Reihenfolge richtet sich nach Risiko und nach dem, was Kunden zuerst fragen werden.

Welle	Termin	Inhalt	Aufwand
1 – Sofort	erledigt 23.9.2026	S1 Microsoft-Rückkanal, S2 Ersatzschlüssel entfernt (Produktion nutzt nachweislich eigenen Schlüssel), S4 Abhängigkeiten, S5 Datenbankfunktionen, S9 Altlasten; offen: O4 Betreiberkonten	6–9 h
2 – Grundschutz	Code 23.9.2026, Abschluss Oktober 2026	S3 Zwei-Faktor (Pflicht für Admins ab 15.10.2026), S6 Sicherheits-Header (CSP zunächst beobachtend), S10 Region Frankfurt, O1 Notfallplan, O2 Sicherheitsblatt, O3 security.txt; **S2b dauerhafte Schlüssellösung:** neuer Schlüssel EMAIL_CRYPT_SECRET_V2 (im Passwort-Manager hinterlegt), Format AES-256-GCM, einmaliger Schlüsseltausch im Systembericht, danach alten Schlüssel aus Vercel entfernen und denselben neuen Wert lokal eintragen	16–26 h
3 – Barrierefreiheit Kern	November 2026	B2 Kontraste, B5 Fokus, B7 Sprunglink, B4 Tastatur, B3 Dialoge	15–24 h
4 – Barrierefreiheit Formulare	Dezember 2026	B1 Feldbeschriftungen, B6 Schriftgrößen, B8 Newsletter, B9 Test und Erklärung	15–26 h
5 – Nachweis	Q1 2027	S7, S8, O5 Wiederherstellungstest, O6 Penetrationstest	3–4 h + extern

Entscheidungen für das Mgmt-Team: Zwei-Faktor für alle Benutzer verpflichtend oder nur für Admins; ob WCAG 2.1 AA offiziell zugesagt wird (dann gehört es in Anlage 3); Budget für den externen Penetrationstest.

Quellen

- WKO: NISG 2026 – neue Pflichten zur Cybersicherheit – https://www.wko.at/it-sicherheit/nis2-uebersicht
- Schönherr: NISG 2026 – Alles, was Sie wissen müssen – https://www.schoenherr.eu/content/oesterreich-nisg-2026-alles-was-sie-wissen-mussen
- Crowell & Moring: CRA-Meldepflichten ab 11. September 2026 – https://www.crowell.com/en/insights/client-alerts/eu-cyber-resilience-act-countdown-11-september-2026-incidentvulnerability-reporting-deadline-is-less-than-100-days-away
- WKO: Informationen zum Barrierefreiheitsgesetz – https://www.wko.at/ce-kennzeichnung-normen/informationen-zum-barrierefreiheitsgesetz
- Sozialministeriumservice: Ausnahmen für Kleinstunternehmen – https://www.sozialministeriumservice.gv.at/Marktueberwachung_digitale_Barrierefreiheit/Informationen_fuer_Unternehmen/Ausnahme_Kleinstunternehmen/Ausnahmen-fuer-Kleinstunternehmen.de.html
- Eigene Prüfung am 23.9.2026: Quellcode software:112, Supabase-Sicherheitsberater, npm audit, Kontrastberechnung nach WCAG